

Risk Register

The table below summarizes all identified risks and the primary recommended action for each.

Severity	Finding	Primary action
High	Default admin credentials remain in seed/docs	Pre-launch fix.
High	Admin-controlled ad HTML is rendered publicly	Pre-launch fix.
High	Article body iframes allow high-risk third-party embed hosts	Pre-launch fix.
High	Production protections depend heavily on NODE_ENV=production	Pre-launch fix.
Medium	Refresh token rotation has a concurrency race	Next hardening pass.
Medium	OG image endpoint can leak unpublished article metadata	Next hardening pass.
Medium	Public series endpoint can expose draft article metadata	Next hardening pass.
Medium	Poll endpoints can expose unpublished article polls	Next hardening pass.
Medium	Article view endpoint can be abused to inflate reads	Next hardening pass.
Medium	2FA recovery codes are shorter than recommended	Next hardening pass.
Medium	Disabling 2FA does not revoke active refresh sessions	Next hardening pass.
Medium	Dormant data processing functions could be dangerous if exposed later	Next hardening pass.
Low	Frontend dependency advisory for Quill	Routine cleanup.
Low	Frontend public robots.txt allows all routes	Routine cleanup.
Low	Accidental empty .crdownload file in public folder	Routine cleanup.